PASSWORD POLICY AUDIT

InternCircle • Project 02 • Cybersecurity

Purpose
This audit reviews the sample password rules in the learner guide and recommends practical changes based on current NIST digital identity guidance. The aim is to make accounts harder to compromise while keeping the rules usable for staff.

1. Review of existing rules

Existing rule	Decision	Reason
At least 8 characters	**Change**	Set a longer minimum and encourage longer passphrases. Longer secrets are generally harder to guess.
Must include a symbol	**Remove**	Fixed symbol rules can lead to predictable patterns. Prioritise length, uniqueness and blocking common or compromised passwords.
Change every 30 days	**Remove**	Routine forced changes can encourage small variations or reuse. Require a change when compromise is suspected or confirmed.
No spaces allowed	**Remove**	Spaces allow passphrases. Systems should support spaces and password-manager paste/autofill where possible.

2. Additional policy checks

• **Common and breached passwords:** Block widely used, predictable, or known-compromised passwords. Do not enter real passwords into untrusted websites.

• **Password managers:** Permit an organisation-approved password manager and allow paste/autofill.

• **Multi-factor authentication (MFA):** Require MFA for email, administrator accounts, remote access and other sensitive services wherever supported.

• **Compromise response:** Change a password promptly if it is exposed, suspected to be compromised, or requested after an incident.

3. Audit conclusion

The sample policy should move away from arbitrary composition rules and routine 30-day resets. A stronger practical policy combines adequate length, unique passwords, breached-password blocking, a password manager, MFA and a clear response to suspected compromise.

4. References

1. NIST SP 800-63B — Digital Identity Guidelines

2. Have I Been Pwned — Pwned Passwords

3. Bitwarden — Password Manager

Safety note: Never submit real or work passwords to unfamiliar websites. Use only approved organisational tools.